



ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

CÁC CƠ CHẾ PHÁT HIỆN XÂM NHẬP MẠNG

Nhóm 9:

Nguyễn Đình Tuấn Minh - 20230048

Vũ Đức Tâm - 20230064

Nguyễn Gia Khánh - 202416803

Nguyễn Đăng Cao Tuấn - 202400119

Giảng viên hướng dẫn: PGS. TS. Nguyễn Linh Giang

ONE LOVE. ONE FUTURE.

Nội dung trình bày

1. Giới thiệu
2. Phát biểu bài toán
3. Mục tiêu
4. Phương pháp tiếp cận
5. Kiến trúc hệ thống
6. Detection Engine
7. Thử nghiệm và kết quả
8. Thảo luận
9. Kết luận



1. Giới thiệu

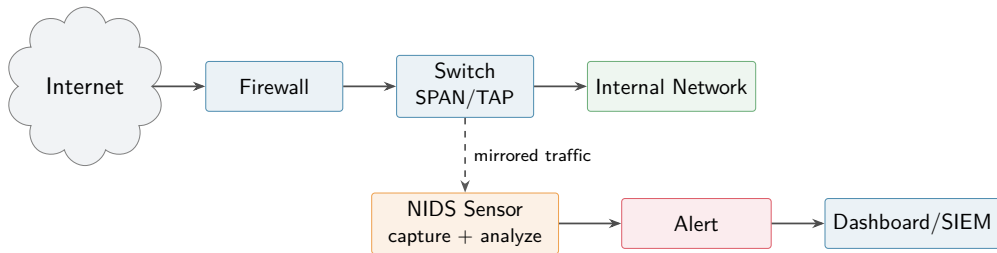
Bối cảnh

- ▶ Tấn công mạng không chỉ xuất hiện ở biên mạng mà còn nằm lẫn trong traffic hợp lệ.
- ▶ Firewall kiểm soát truy cập, nhưng không luôn đủ để nhận diện scan, flood, tunneling hoặc payload độc hại.
- ▶ Network Intrusion Detection System (NIDS) quan sát packet/flow và sinh cảnh báo cho người vận hành.

Trọng tâm

- ▶ Tìm hiểu cơ chế phát hiện xâm nhập ở tầng mạng.
- ▶ Xây dựng prototype NIDS nhỏ bằng Python.
- ▶ Demo các nhóm rule behavior-based và signature-based.

NIDS trong hệ thống phòng thủ



NIDS thường nằm ngoài đường truyền chính, nhận bản sao traffic để phân tích và không trực tiếp thay đổi luồng packet.

2. Phát biểu bài toán

Bài toán đặt ra

- ▶ Cần phát hiện sớm các hành vi bất thường hoặc độc hại trong network traffic.
- ▶ Traffic đầu vào có thể đến từ PCAP hoặc live interface, gồm nhiều giao thức khác nhau.
- ▶ Cảnh báo cần có bằng chứng giải thích được: rule nào kích hoạt, vì sao kích hoạt, nguồn/đích liên quan.

Thách thức

Signature rõ ràng nhưng dễ bỏ sót biến thể mới; anomaly/behavior bắt được hành vi lạ nhưng phụ thuộc threshold và dễ false positive nếu thiếu ngữ cảnh.

3. Mục tiêu

Mục tiêu chính

- ▶ Trình bày các nhóm cơ chế phát hiện xâm nhập mạng.
- ▶ Thiết kế pipeline xử lý từ packet tới alert.
- ▶ Triển khai detection engine có thể kiểm thử và demo.

Phạm vi

- ▶ Không xây dựng IDS production thay thế Suricata.
- ▶ Tập trung vào minh họa scan, flood, DNS tunneling và HTTP/DNS signature.
- ▶ Không xử lý TLS decryption hoặc TCP stream reassembly đầy đủ.

4. Phương pháp tiếp cận

Behavior-based detection

- ▶ Theo dõi chuỗi sự kiện theo source IP và time window.
- ▶ Đếm số port, số ICMP, số SYN hoặc số DNS query có dấu hiệu tunneling.
- ▶ Phù hợp với scan, flood và tunneling.
- ▶ Threshold trong prototype là ngưỡng lab/demo, cần hiệu chỉnh theo baseline từng mạng thực tế.

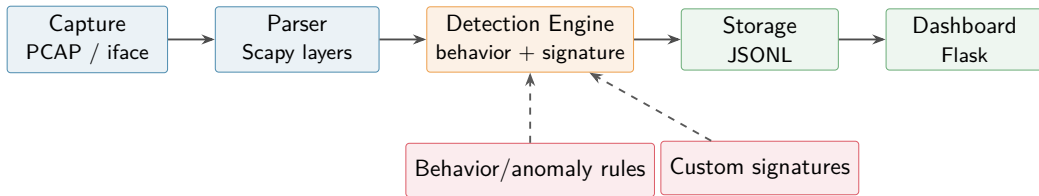
Signature-based detection

- ▶ So khớp traffic với rule đã biết.
- ▶ Bao gồm content/header rule, DNS domain blacklist, User-Agent hoặc payload pattern đã biết.
- ▶ Phù hợp với HTTP SQLi, scanner User-Agent, DNS/payload pattern.

So sánh các cơ chế phát hiện

Cơ chế	Ý tưởng	Vai trò
Signature-based	Match payload/header với mẫu tấn công đã biết.	Triển khai rule Suricata-style subset và DNS domain blacklist.
Behavior-based	Quan sát tần suất và chuỗi hành vi theo thời gian.	Triển khai sliding-window rules cho scan/flood/DNS tunneling.
Statistical anomaly	Học baseline rồi báo động khi traffic lệch chuẩn.	Thảo luận, chưa triển khai.
Stateful protocol	Theo dõi session/protocol state và violation.	Nêu hướng mở rộng.
Correlation/Hybrid	Kết hợp nhiều signal thành incident có ngữ cảnh.	Ví dụ: gom port scan → HTTP SQLi thành incident có timeline.

5. Kiến trúc hệ thống



Luồng thực thi

main.py đọc packet, parser.py chuẩn hóa thành PacketEvent, NIDSEngine đánh giá rule, AlertStore append JSONL, dashboard đọc file và hiển thị thống kê.

Lý do chuẩn hóa

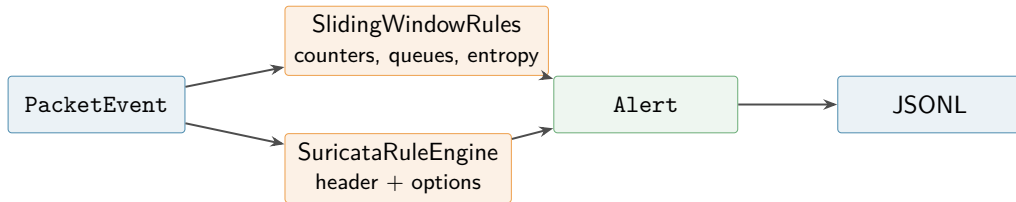
- ▶ Raw packet phụ thuộc lớp giao thức và API của Scapy.
- ▶ Detection engine cần schema ổn định để rule dễ viết, dễ test.
- ▶ Cùng một alert format dùng được cho cả behavior và signature.

Trường tiêu biểu

timestamp, src_ip, dst_ip
src_port, dst_port, protocol
tcp_flags, icmp_type
dns_query
http_method, http_uri
http_host, http_user_agent
payload_text

Module	File chính	Vai trò
Capture	nids/capture.py	Đọc PCAP hoặc sniff live interface.
Parser	nids/parser.py	Chuyển packet thành PacketEvent.
Orchestrator	nids/engine.py	Đếm packet, gọi rule engine, ghi alert.
Behavior rules	nids/rules/behavior.py	Sliding window cho scan/flood/DNS tunneling.
Signature rules	nids/rules/parser.py, nids/rules/engine.py	Match rule Suricata-style subset do người dùng nạp.
Dashboard	dashboard/app.py	Đọc JSONL, tính thống kê, render web.

6. Detection Engine



Detection engine chạy song song hai lớp: behavior/anomaly rules phát hiện chuỗi hành vi bất thường; signature rules phát hiện mẫu đã biết trong header, HTTP/DNS buffer hoặc domain blacklist.

Behavior/anomaly rules và signature rules

Rule	Attack	Nhóm phát hiện	Điều kiện lab/demo	Severity
RULE-001	Port Scan	Behavior-based	≥ 20 TCP destination ports từ một source trong 10s.	Medium
RULE-002	ICMP Ping Flood	Behavior-based	≥ 100 ICMP request packets trong 10s.	High
RULE-003	TCP SYN Flood	Behavior-based	≥ 100 TCP SYN packets without ACK tới cùng destination service trong 10s.	High
RULE-004	DNS Tunneling	Behavior/anomaly-based	≥ 5 DNS query đáng ngờ từ cùng source trong 30s.	Medium

Signature rules sẽ được nạp thêm bên ngoài theo dạng Suricata-style subset (không tương thích đầy đủ với Suricata/Snort).

Sliding window

- ▶ Mỗi source IP có queue sự kiện gần nhất.
- ▶ Khi event mới đến, loại bỏ event ngoài cửa sổ thời gian.
- ▶ Vượt threshold thì tạo alert kèm evidence.

Context filtering

- ▶ Port scan chỉ đếm probe flags như SYN, FIN, NULL, Xmas.
- ▶ Xmas scan tương ứng FIN + PSH + URG.
- ▶ ACK scan cần TCP state tracking; prototype chưa khẳng định phát hiện ACK scan chính xác.
- ▶ ICMP flood chỉ đếm request-side: type 8, 13, 17.
- ▶ Cooldown 5 giây cho cùng rule_id và key để tránh alert trùng lặp.

Dấu hiệu được dùng

- ▶ Query name dài ít nhất 100 ký tự.
- ▶ Một label dài ít nhất 45 ký tự.
- ▶ Label dài ít nhất 24 ký tự và entropy ≥ 3.8 .
- ▶ Có ít nhất 5 query đáng ngờ từ cùng source trong 30 giây.

Entropy Shannon

$$H(X) = - \sum_i p(x_i) \log_2 p(x_i)$$

Ý nghĩa

Label được encode/base64 thường dài, phân bố ký tự đều hơn tên miền bình thường, nên entropy cao hơn.

False positive

CDN, tracking, DKIM, ACME challenge hoặc service discovery cũng có thể tạo domain dài; thực tế nên kết hợp whitelist, NXDOMAIN rate, unique subdomain, qtype và reputation.

Rule shape

Ví dụ

```
alert http any any -> any 80
(msg:"sqlmap UA";
http.user_agent;
content:"sqlmap"; nocase;
sid:1000002; rev:1;)
```

Subset prototype hỗ trợ

- ▶ Protocol: ip, tcp, udp, icmp, dns, http.
- ▶ Option: msg, sid, priority, content, pcre, nocase.
- ▶ Sticky buffer: pkt_data, dns.query, http.uri, http.user_agent, http.host.
- ▶ DNS blacklist có thể viết bằng custom rule dùng dns.query + pcre.

Chưa hỗ trợ đầy đủ

flow, depth/offset, distance/within, fast_pattern, flowbits, byte_test, TCP stream inspection, file_data.

Trường chính

- ▶ timestamp
- ▶ rule_id
- ▶ attack_type
- ▶ detection_method
- ▶ severity
- ▶ source_ip, destination_ip
- ▶ description
- ▶ evidence

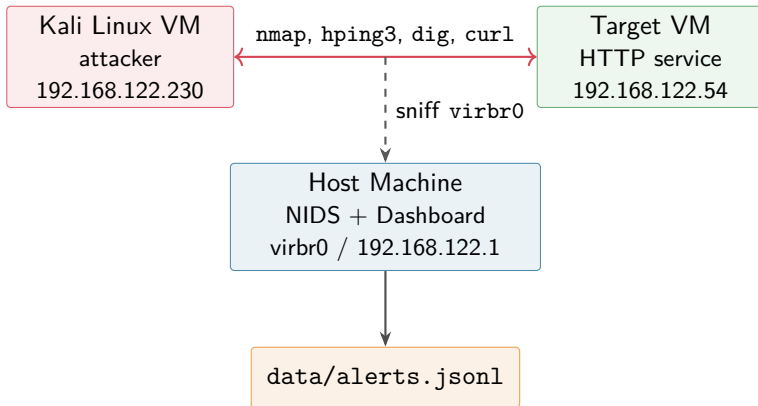
Ví dụ evidence

```
{  
  "count": 20,  
  "unique_ports": [21,22,80,...]  
}
```

Giá trị

Evidence giúp giải thích vì sao alert xuất hiện, hỗ trợ người vận hành kiểm tra nhanh thay vì chỉ nhìn một nhãn tấn công.

7. Thử nghiệm và kết quả



Môi trường thử nghiệm chạy trong mạng ảo cô lập KVM/QEMU. NIDS bắt gói ở interface virbr0, phân tích lưu lượng giữa Kali và Target, sau đó ghi cảnh báo ra JSONL để dashboard hiển thị.

Khởi động hệ thống

- ▶ Cài phụ thuộc: `pip install -r requirements.txt`.
- ▶ Chạy dashboard: `python dashboard/app.py`.
- ▶ Chạy NIDS: `sudo .venv/bin/python main.py -iface virbr0 -rules custom.rules -limit 0`.

Điều kiện ghi nhận

- ▶ Engine nạp các luật tùy chỉnh kiểu Suricata-style.
- ▶ Traffic tấn công được sinh từ Kali trong cùng subnet.
- ▶ Mỗi cảnh báo có `rule_id`, `severity`, IP nguồn/đích và `evidence`.

Kịch bản thử nghiệm: Behavior/anomaly

Kịch bản	Detection signal	Rule
Port scan	≥ 20 cổng TCP khác nhau từ cùng một source trong 10 giây	RULE-001
ICMP Flood	≥ 100 ICMP Echo Request từ cùng một source trong 10 giây	RULE-002
TCP SYN Flood	≥ 100 gói SYN không kèm ACK tới cùng một dịch vụ trong 10 giây	RULE-003
DNS tunneling	≥ 5 truy vấn DNS có nhãn dài và entropy cao từ cùng một source trong 30 giây	RULE-004

Các kịch bản này kiểm tra nhóm luật dùng cửa sổ trượt thời gian và thống kê hành vi.

Kịch bản thử nghiệm: Signature/threshold

Kịch bản	Detection signal	SID
DNS example.com	dns.query khớp domain trong luật tùy chỉnh	1000101
sqlmap Agent	http.user_agent chứa chuỗi sqlmap	1000002
SQLi GET	URI sau decode chứa mẫu ' OR '1'='1	1000001
SQLi POST	pkt_data chứa mẫu SQL Injection trong phần body request	1000003
Web repeat	GET vượt ngưỡng 5 lần trong 10 giây theo source IP	900004
.env Access	URI chứa đường dẫn tệp cấu hình nhạy cảm .env	1000005

Các kịch bản này kiểm tra nhóm luật chữ ký và cơ chế `detection_filter`.

Kết quả behavior/anomaly

Kịch bản	Luật	Alert	Evidence chính	Khuyến nghị
Port Scan	RULE-001	1	20 cổng TCP: 21, 22, 23, 25, 53, 80, 110, 135, 139, 143, 443, 445...	Chặn IP quét, ẩn cổng dịch vụ nhạy cảm.
ICMP Flood	RULE-002	1	100 gói ICMP Echo Request trong 10 giây	Tắt phản hồi ping hoặc rate-limit ICMP.
TCP SYN Flood	RULE-003	1	100 gói SYN tới cổng 80 không có ACK	Bật SYN Cookies, rate-limit kết nối TCP mới.
DNS Tunnel	RULE-004	1	5 truy vấn/30 giây, nhãn 54 ký tự, entropy 4.276	DNS whitelist, giới hạn DNS resolver ngoài.

Bốn kịch bản hành vi/bất thường đều kích hoạt đúng luật dự kiến, với evidence đủ để giải thích nguyên nhân cảnh báo.

Kết quả signature/threshold

Kịch bản	Luật	Alert	Evidence chính	Khuyến nghị
DNS Signature	1000101	8	dns.query chứa example.com	DNS sinkhole/chặn domain độc hại đã biết.
sqlmap Agent	1000002	1	User-Agent chứa sqlmap	Lọc scanner User-Agent bằng WAF.
SQLi GET	1000001	1	URI decode chứa ' OR '1'='1	Prepared Statements, kiểm tra input.
SQLi POST	1000003	1	Payload TCP chứa mẫu SQL Injection	Prepared Statements và validation phía server.
Brute Force/Web repeat	900004	7	Vượt ngưỡng 5 lần GET/10 giây từ cùng IP	Fail2Ban, rate-limit request.
.env Access	1000005	1	URI chứa .env	Cấm truy cập file ẩn như .env, .git.

Dữ liệu lấy từ data/alerts.jsonl: 10 kịch bản đều kích hoạt đúng luật dự kiến; tổng cộng 23 cảnh báo trong môi trường lab.

Kết quả đạt được

- ▶ True Positive đạt 100% với các kịch bản đã thiết lập trong lab.
- ▶ Parser decode URL-encoded URI trước khi so khớp SQLi GET.
- ▶ Rule tùy chỉnh có thể mở rộng mà không sửa mã nguồn engine.
- ▶ Dashboard trực quan hóa nhanh thống kê cảnh báo.

Giới hạn khi diễn giải

- ▶ Kết quả phản ánh môi trường lab có kiểm soát, chưa phải đo kiểm production.
- ▶ Chưa đánh giá precision, recall, false positive rate trên dataset lớn.
- ▶ Hiệu năng bắt gói bằng Python/Scapy còn giới hạn khi traffic tăng cao.

8. Thảo luận: điểm đạt được và hạn chế

Điểm đạt được

- ▶ Pipeline module rõ ràng: capture, parser, engine, storage, dashboard.
- ▶ Behavior rules có threshold và evidence dễ giải thích.
- ▶ Signature engine dùng cú pháp Suricata-style subset.
- ▶ Có script demo và unit test cho rule engine.

Hạn chế

- ▶ Chưa reassemble TCP stream; payload chia nhỏ có thể bị bỏ sót.
- ▶ Chưa xử lý IP fragmentation, segmentation/out-of-order.
- ▶ Không phân tích TLS/HTTPS, DoH, DoT nếu thiếu visibility.
- ▶ Payload encode/obfuscate có thể evasion.
- ▶ SPAN/TAP có thể mất packet hoặc asymmetric routing.
- ▶ Threshold tĩnh, chưa học baseline theo từng môi trường.

- ▶ Bổ sung IP defragmentation và TCP stream reassembly.
- ▶ Bổ sung stateful protocol analysis cho TCP/HTTP/DNS.
- ▶ Thêm whitelist/baseline học từ traffic bình thường để giảm false positive.
- ▶ Thêm correlation engine: gom port scan, flood, HTTP SQLi thành incident có timeline.
- ▶ Đánh giá trên PCAP lớn/dataset công khai và báo cáo precision, recall, false positive rate.

Kết luận

- ▶ Project mô phỏng được luồng hoạt động cốt lõi của một NIDS ở mức học tập.
- ▶ Behavior-based detection và signature-based detection bổ sung cho nhau.
- ▶ Dashboard biến alert thô thành thông tin dễ quan sát, phục vụ demo và đánh giá.

Thông điệp chính

Một hệ thống phát hiện xâm nhập mạng hiệu quả cần vừa có rule rõ ràng cho mẫu đã biết, vừa có cơ chế quan sát hành vi để nhận diện dấu hiệu bất thường.

- [1] Open Information Security Foundation, *Suricata User Guide*.
- [2] Scapy Project, *Scapy Documentation*.
- [3] Gordon Lyon, *Nmap Network Scanning*.
- [4] Snort Project, *Snort 3 Rule Writing Guide*.
- [5] NIST SP 800-94, *Guide to Intrusion Detection and Prevention Systems*.
- [6] The MITRE Corporation, *MITRE ATT&CK Enterprise Matrix*.